

INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

GRC102 – WEEK 3 PRACTICAL LABORATORY

Roles, Responsibilities and Accountability in Security Governance

Student Name: Imelda Sanya

Registration Number: C11/26/CGRCE/17576

Executive Summary

TechGlobal has grown quickly, but its security governance has not grown at the same pace. The main problem is that too many security decisions sit with the IT Director, while business units make some decisions locally. There is also no formal governance committee and limited reporting to the CEO and Board.

My proposed model separates oversight, risk acceptance and technical operation. The Board keeps oversight of material cyber risk and risk appetite. The CEO remains accountable for the business response. The CISO leads security, the CRO/Risk function provides challenge around risk acceptance, Legal handles regulatory and contractual issues, Finance controls financial governance, HR handles people-related controls, and IT operates the technology.

The model also introduces an Executive Security Council, a cross-functional Security Governance Committee and an Incident and Resilience Working Group. A RACI matrix makes the decision rights clearer, while a three-level escalation model provides a route from operational teams to executives and, when necessary, the Board.

The design is intentionally practical. TechGlobal has about 2,500 employees, so it needs enough governance to avoid confusion without creating a committee for every decision.

Evidence Bundle 1 – Governance Architecture and Stakeholder Map

1.1 Governance Gap Assessment

Current weakness	What it means in practice	Business / risk consequence
IT Director holds several roles	The same function can own security controls, make operational	There is limited independent challenge and a higher chance that a risk

	decisions and influence risk acceptance.	is accepted because of operational pressure.
No formal security governance committee	Security issues are handled in separate conversations rather than through one regular cross-functional forum.	Important decisions can be delayed or made without Finance, Legal, Risk or business input.
Business units make local security decisions	Different offices or teams may use different approaches to the same type of risk.	Controls become inconsistent and the organisation has difficulty knowing its overall risk position.
Limited Board visibility	The Board receives little structured information about cyber risk, exceptions or major control gaps.	Material risks may not be escalated early enough and Board oversight is weakened.
No clear escalation path	Teams do not have a common definition of when an issue should move from operational management to executives or the Board.	Serious incidents can remain at the wrong level for too long.
Risk ownership is unclear	Security may identify a risk, but the business owner who is actually accepting the risk may not be clear.	Remediation can stall because nobody has clear decision authority.

1.2 Stakeholder Map

Stakeholder	Authority / influence	Main interest	Information needed	Governance contribution
Board / Board Risk or Audit Committee	High	Risk appetite, major exposure, resilience, accountability	Top risks, material incidents, exceptions, trends, assurance results	Oversight, challenge and review of material cyber risk
CEO	High	Business performance, growth and acceptable risk	Material incidents, business impact, major decisions and funding needs	Executive accountability and final business decisions

CISO	High in security	Security strategy, control effectiveness, incident readiness	Risk register, control metrics, incidents, vulnerabilities, third-party risk	Leads security governance and gives security advice
CRO / Risk	High in risk	Enterprise risk, risk appetite and risk acceptance	Risk assessments, residual risk, exceptions and trends	Independent challenge and enterprise risk integration
Legal / Compliance	Medium-High	Regulatory duties, contracts, privacy and evidence	Data involved, jurisdictions, contracts, incident facts	Legal advice and notification decisions
Finance	Medium-High	Budget, financial loss and investment value	Security spend, loss estimates, recovery costs	Budget governance and financial impact assessment
HR	Medium	People risk, conduct and employment processes	Joiner/mover/leaver issues, awareness, disciplinary matters	People controls, awareness and insider-risk coordination
IT / Technology	High operationally	Secure service delivery and availability	Technical risks, vulnerabilities, architecture and incidents	Implements and operates technical controls
Business Unit Leaders	High for their services	Operational performance and local risk	Service impact, business risks, control requirements	Own business risk and implement agreed controls

1.3 Proposed Security Governance Organisation Chart

Level	Governance relationship
BOARD / BOARD RISK OR AUDIT COMMITTEE	Receives material cyber-risk reporting; challenges management; reviews risk appetite and major unresolved issues.
↓ Oversight	
CEO	Overall executive accountability for

	business risk and major cyber decisions.
↓ Executive direction	
EXECUTIVE SECURITY COUNCIL	CEO, CISO, CRO/Risk, CIO/IT Director, Finance, Legal/Compliance and selected business leaders. Sets direction and resolves cross-functional issues.
↓ Governance	
SECURITY GOVERNANCE COMMITTEE	CISO-led working forum with Risk, Legal, Finance, HR, IT and Business Unit representatives. Reviews policies, risk, exceptions, projects and metrics.
↓ Operational coordination	
INCIDENT & RESILIENCE WORKING GROUP	SOC/IT, Incident Response, Business Continuity, Legal/Privacy and relevant business teams. Handles operational readiness and exercises.
↔ Business Units	Business Unit Security Representatives feed local risks into the Security Governance Committee instead of creating separate security structures.

1.4 How Information Moves

1. Operational teams identify an issue, record it and classify it using the agreed severity and escalation criteria.
2. The CISO and relevant business owner review the issue. Risk, Legal, Finance or HR are added when their areas are affected.
3. Issues that are within normal risk tolerance stay at operational or committee level and are tracked to closure.
4. Issues outside risk tolerance, with major business impact or significant regulatory exposure move to the Executive Security Council and CEO.
5. Material risks that need Board oversight, risk acceptance beyond delegated authority or major strategic decisions are reported to the Board Risk/Audit Committee.

1.5 Why this structure fits TechGlobal

For a 2,500-employee organisation, I would not create a large number of separate committees. The structure above keeps the number of formal forums small and gives each one a clear purpose. The Security Governance Committee handles regular governance work, while the Executive Security Council deals with issues that need

executive decisions. The working group can focus on incident and recovery readiness without taking strategic decisions away from management.

This also helps the five offices work in a more consistent way. Business Unit representatives can raise local issues, but the organisation still has one overall governance process. The model supports the NIST CSF 2.0 Govern function, which places emphasis on cybersecurity governance, roles, responsibilities, authorities and alignment with enterprise risk management. [1]

The aim is not to make every security decision a Board decision. The aim is to make sure the right person makes each decision, with the right information and a clear record of why the decision was made.

Evidence Bundle 2 – Governance Responsibility and Authority

2.1 Cross-functional Governance Responsibility Matrix

Role	Purpose	Key responsibilities	Decision authority	Reports / escalates	KPIs / evidence
Board	Provide oversight and challenge on material cyber risk.	Set oversight expectations; review risk appetite; challenge major exposure and remediation.	Accept or challenge material risk within Board authority; request further assurance.	Receives quarterly risk reports and immediate material-risk escalation.	Material risks outside appetite; Board actions closed on time.
CEO	Provide overall business accountability for cyber risk.	Set executive direction; resolve major business trade-offs; sponsor governance.	Approve major business decisions and executive risk responses.	Receives material incident and risk escalations.	Major actions delivered; material risks have owners and deadlines.
CISO	Lead the security programme and security governance.	Set security strategy; advise on risk; oversee controls, incidents and reporting.	Approve security standards within delegated authority; recommend risk treatment.	Reports to CEO/Executive Council and Board committee as required.	Critical control coverage; incident readiness; remediation progress.
CRO /	Connect	Maintain risk	Challenge or	Reports	Risk

Risk	cyber risk to enterprise risk management.	methodology; challenge risk acceptance; aggregate enterprise risk.	approve risk treatment/acceptance within delegated authority.	enterprise risk position to CEO and Board.	assessments completed; overdue exceptions; risks outside appetite.
Legal / Compliance	Protect the organisation from legal and regulatory exposure.	Advise on privacy, contracts, regulatory duties and evidence.	Own legal advice and regulatory notification recommendation.	Escalates regulatory issues to CEO/CISO and relevant Board forum.	Notification decisions within required time; contract/security clauses reviewed.
Finance	Manage the financial side of security decisions.	Support budget planning; assess losses; validate major financial impacts.	Approve spend within delegated financial authority.	Reports material losses and budget exceptions to CEO/Board.	Security budget variance; loss estimates completed; benefits from security spend.
HR	Manage people-related security governance.	Own awareness, conduct, disciplinary processes and joiner/mover/leaver governance.	Approve HR actions within HR authority; advise on people-risk cases.	Reports significant people-risk trends and issues to relevant committees.	Training completion; leaver access closure; overdue people actions.
IT / Technology	Operate technology securely and maintain services.	Implement controls; manage vulnerabilities; support architecture, availability and recovery.	Approve technical implementation decisions within delegated authority.	Reports operational risks and control performance to CISO/committee.	Critical vulnerabilities overdue; service availability; control implementation rate.

2.2 Role Profiles / Responsibility Cards

The matrix above gives the short version. The following points explain how I would use the roles in practice.

Board: The Board should stay out of day-to-day security operations. Its role is to understand whether the organisation's cyber risk is within the agreed appetite, challenge management when it is not, and make sure major risks are not hidden in operational reporting.

CEO: The CEO is the point where cyber risk connects to business priorities. If a serious incident affects customers, revenue or critical services, the CEO decides the wider business response with advice from the CISO, Risk, Legal and other functions.

CISO: The CISO owns the security programme and is the main security adviser to management. The CISO should be able to raise a concern even when it is uncomfortable for an operational team or project.

CRO / Risk: Risk should not run security operations. Its value is independent challenge: checking whether risk is understood, whether treatment is reasonable and whether the person accepting the risk has the authority to do so.

Legal / Compliance: Legal and Compliance should be involved early when incidents or projects create regulatory, privacy or contractual questions. Legal should not be expected to make technical decisions.

Finance: Finance should be involved where security decisions involve material spending, financial exposure or business recovery costs. This helps security investment compete on clear business information rather than technical preference alone.

HR: HR owns the people side of security governance. This includes awareness, employee conduct, disciplinary processes and joiner/mover/leaver controls. HR should work with IT and Security rather than operating those controls in isolation.

IT / Technology: IT is responsible for operating and implementing technology controls. It should not be the only function deciding whether the risk created by those controls is acceptable.

2.3 Authority Overlap and Conflict Resolution

Overlap / conflict	Why it could cause a problem	How I would resolve it
IT wants to accept a security exception because	The team delivering the project has an interest in	IT can explain the technical constraint, but the

a project deadline is close.	keeping the project moving.	business risk owner and Risk/CISO decide whether the exception is acceptable. Exceptions must have an expiry date.
CISO identifies a serious risk while the business owner wants to accept it.	Security and the business may have different views of the impact.	Use the risk appetite and delegated authority matrix. If the risk is outside the business owner's authority, escalate it rather than letting the CISO and business owner negotiate informally.
Legal wants more evidence before a notification decision while Security wants to communicate quickly.	The teams have different priorities during a fast-moving incident.	Use a pre-agreed incident process. Security provides facts and timeline; Legal/Privacy gives the regulatory assessment; CEO decides wider business communications where needed.
Finance controls budget while the CISO controls security priorities.	A security priority may be delayed if it is treated only as an IT budget request.	CISO and Finance jointly prepare the business case; CEO/Executive Council resolves competing strategic priorities.

Evidence Bundle 3 – Security Governance Committee Ecosystem

3.1 Committee Structure

Forum	Chair	Members	Purpose	Frequency	Main outputs
Executive Security Council	CEO	CEO, CISO, CRO/Risk, IT Director, Finance, Legal/Compliance and selected BU leaders	Strategic decisions, major risk acceptance, investment priorities and material issues.	Quarterly ; ad hoc for major incidents	Decisions, risk acceptance, priorities and escalations
Security Governance Committee	CISO	CISO, Risk, Legal, Finance, HR, IT and BU security representatives	Review security strategy, policies, risk register, exceptions, projects, metrics and third-party issues.	Monthly	Actions, decisions, risk updates and recommendations
Incident & Resilience Working Group	CISO or Incident Lead	SOC/IT, Incident Response, Business Continuity, Legal/Privacy, Communications and affected BU	Prepare for major incidents, run exercises, review lessons learned and test recovery arrangements.	Monthly; exercises quarterly	Exercise results, recovery gaps, lessons learned

3.2 Terms of Reference – Security Governance Committee

- Purpose: provide one regular cross-functional forum for security governance decisions and follow-up.
- Scope: security strategy, policies, enterprise cyber-risk, exceptions, control performance, major vulnerabilities, third-party risk, awareness, resilience and remediation.

- Authority: make decisions within delegated authority, recommend decisions to the Executive Security Council and escalate risks outside agreed tolerance.
- Quorum: CISO plus representatives from Risk and at least two of Legal, IT, Finance or the affected business unit.
- Decision rule: decisions should identify the owner, rationale, due date and review date. Unresolved disagreements are escalated instead of being left open.
- Records: agenda, minutes, decision log, action tracker and risk/exception register.
- Review: terms of reference reviewed annually or after a major organisational change.

3.3 Sample Committee Agenda

Time	Agenda item	Owner	Expected outcome
5 min	Opening and actions from last meeting	CISO	Confirm previous actions and overdue items
10 min	Current cyber-risk dashboard	CRO/Risk	Agree risks needing escalation
10 min	Security incidents and lessons learned	CISO / IT	Confirm corrective actions
10 min	Vulnerability and control performance	IT / Security	Agree priorities and owners
10 min	Third-party and project security	Risk / Procurement / BU	Review high-risk suppliers or projects
10 min	Policy / exception decisions	CISO / Risk	Approve, reject or escalate
5 min	Regulatory / legal updates	Legal	Identify required actions
5 min	Decisions and next actions	CISO	Confirm owners and deadlines

3.4 Sample Decision Log

Date	Decision / issue	Decision owner	Decision	Rationale	Action / owner	Review date
02 Oct 2026	Legacy application cannot meet MFA deadline	CISO + Risk	Approve temporary exception for 30 days	Business service is critical, but compensating controls are required	IT to implement monitoring; BU owner to fund upgrade	02 Nov 2026

06 Nov 2026	Critical supplier has overdue security assessment	CRO/Risk	Escalate supplier to Executive Security Council	Supplier supports a key service and evidence is incomplete	Procurement + CISO to complete assessment or contingency plan	20 Nov 2026
04 Dec 2026	Repeated critical vulnerabilities in internet-facing systems	IT Director + CISO	Set a seven-day remediation target and monthly executive reporting	Repeated overdue items create avoidable exposure	IT Security to track remediation; CISO to report trend	08 Jan 2027

3.5 Business Unit Participation

Each major Business Unit should nominate a security representative. The representative does not become a second CISO. Their role is to bring business risks, upcoming changes and control issues into the central governance process and take approved actions back to the business. This keeps local knowledge without creating separate security silos.

3.6 Twelve-Month Governance Calendar

Month	Main governance activity	Lead
Oct 2026	Annual security strategy review; committee terms confirmed	CISO / Executive Council
Nov 2026	Third-party risk review; privileged access review	Risk / Procurement / IT
Dec 2026	Board cyber-risk report; budget checkpoint	CISO / Finance
Jan 2027	Security awareness and HR control review	HR / CISO
Feb 2027	Incident tabletop exercise	Incident Working Group
Mar 2027	Architecture and major project security review	IT / CISO
Apr 2027	Enterprise cyber-risk assessment refresh	Risk / CISO
May 2027	Vulnerability remediation deep review	IT / Security
Jun 2027	Business continuity and recovery exercise	BCM / IT / BU
Jul 2027	Third-party reassessment	Procurement / Legal / Risk

	and contract review	
Aug 2027	Board assurance and control-effectiveness review	CISO / Internal Audit
Sep 2027	Annual governance effectiveness review and next-year plan	CEO / CISO / Risk

Evidence Bundle 4 – RACI Accountability Matrix

RACI is used here to make the working relationship clear: R = Responsible for doing the work, A = Accountable for the decision or outcome, C = Consulted, and I = Informed. I have tried to keep one clear Accountable role for each activity, as required by the laboratory brief.

Activity	Board	CEO	CISO	CRO/Risk	Legal	Finance	HR	IT	BU
Cybersecurity strategy approval	A	C	R	C	C	C	I	C	C
Security policy approval	A	C	R	C	C	I	C	C	I
Enterprise cyber-risk assessment	I	C	R	A	C	C	C	C	R
Risk acceptance	A	C	C	A	C	I	I	C	R
Security budget approval	I	A	R	C	I	C	I	C	C
Security architecture approval	I	I	A	C	C	I	I	R	C
Third-party security review	I	I	A	R	C	C	I	C	R
Access governance	I	I	A	C	I	I	C	R	R
Incident response governance	I	A	R	C	C	C	C	R	C
Material	C	A	R	C	C	C	I	R	C

incident escalation									
Regulatory notification decision	I	C	R	C	A	I	I	C	C
Security awareness programme	I	C	A	C	C	I	R	C	R
Vulnerability remediation oversight	I	C	A	C	I	I	I	R	R
Business continuity / recovery governance	C	A	R	C	C	C	C	R	R
Board cyber-risk reporting	A	C	R	C	C	I	I	C	C

4.1 Problematic RACI Assignments to Watch

Issue	Why it is a problem	Adjustment
IT is both R and A for access governance.	The team operating access could also be the team deciding whether access is appropriate.	CISO remains accountable for governance; IT is responsible for implementation; business owners approve business need.
Board is shown as accountable for every risk acceptance.	This would push normal operational decisions to the Board.	Use the Board only for material risk outside delegated authority. CRO/Risk and authorised business owners handle normal acceptance.
Legal is accountable for every part of an incident.	Legal has an important role, but cannot own the technical response or business continuity.	Legal is accountable for the regulatory notification decision, while CISO and IT lead technical response and the CEO leads major business decisions.

4.2 One-Page RACI Implementation Guide

1. Use the RACI during planning. Before starting a major security project, the project owner checks who is Accountable, Responsible, Consulted and Informed.
2. Do not use RACI as a substitute for a decision. If the accountable person needs information from a consulted team, that input should be obtained before approval.
3. If two teams both believe they are Accountable, stop and resolve the conflict before proceeding. The CISO or CRO/Risk can refer the issue to the Executive Security Council if needed.
4. During incidents, use the RACI together with the incident response plan. The matrix helps identify who makes decisions; it does not replace the incident commander or technical procedures.
5. Review the matrix at least annually and after major organisational changes, acquisitions or serious incidents.
6. Keep the approved RACI in the governance repository so managers use one version rather than local copies.

Evidence Bundle 5 – Cyber-Risk Escalation and Segregation of Duties

5.1 Major Cyber-Risk Escalation Workflow

Step	What happens	Main owner	Output
1. Detect / identify	SOC, IT or a business team identifies a cyber event, control gap or emerging risk.	Operational team	Initial incident/risk record
2. Classify	Assess severity, affected services/data, financial exposure, regulatory issues and business impact.	Incident Lead / CISO	Severity and escalation level
3. Contain / protect	Take immediate actions to limit damage while preserving evidence and keeping key stakeholders informed.	IT / Security	Containment status and technical evidence
4. Cross-functional	Bring in Risk, Legal,	CISO	Updated risk and

review	Finance, HR or Business Unit leaders depending on the issue.		impact assessment
5. Executive decision	CEO/Executive Security Council decides on major business actions, funding, risk treatment or acceptance within authority.	CEO / Executive Council	Recorded decision and action owner
6. Board escalation	Material issues outside appetite or delegated authority are taken to the Board Risk/Audit Committee.	CEO / CISO	Board decision, challenge or oversight action
7. Track and close	Actions are assigned, reviewed and evidenced until the issue is closed or formally accepted.	Risk / CISO / owner	Closed decision record and lessons learned

5.2 Escalation Threshold Table

Level	Example trigger	Decision authority	Required notification	Target response
Level 1 – Operational	Low/medium impact; no material regulatory exposure; within risk tolerance; one service/team affected.	Operational owner / CISO delegate	Relevant team and business owner	Same business day
Level 2 – Executive	High severity; significant service disruption; major vulnerability; risk outside local authority; important supplier issue.	CEO / Executive Security Council	CISO, CRO/Risk, Legal/Finance as relevant	Immediate; executive review within hours
Level 3 –	Critical incident;	CEO with	Board, Legal,	Immediate

Material / Board	material data exposure; prolonged critical-service outage; major financial/reputational impact; risk outside enterprise appetite or Board authority.	Board Risk/Audit Committee oversight	Risk, Finance and other required stakeholders	escalation; continuous updates
------------------	--	--------------------------------------	---	--------------------------------

5.3 Segregation-of-Duties / Accountability Weakness Register

ID	Weakness / conflict	Risk created	Roles involved	Recommended control	Residual risk / review
1	IT Director can approve a security exception for a system they own.	Delivery pressure may override security concerns.	IT, CISO, Risk, BU owner	System owner provides facts; CISO/Risk assess the risk; authorised risk owner approves; exception expires automatically.	Medium; review monthly until closed
2	IT can create and approve privileged access for its own administrators.	Excessive or inappropriate access may not be challenged.	IT, IAM, CISO, BU owner	Separate request and approval; privileged access logged and reviewed quarterly.	Low-Medium; quarterly review
3	Incident responder decides alone whether a regulatory notification is required.	Technical staff may miss legal or privacy requirements .	Security, Legal/Privacy, CISO	Use a joint legal/security decision point with documented facts and deadline tracking.	Low; test in exercises
4	Procurement can approve a critical supplier without security review.	Commercial pressure may result in an unmanaged third-party risk.	Procurement, CISO, Risk, BU owner	Critical suppliers require security due diligence and risk acceptance before onboarding/renewal.	Medium; annual supplier review
5	Business Unit leader can accept a risk	The organisation may carry risk	BU, Risk, CRO, CEO	Use a documented risk appetite and delegation matrix;	Low-Medium; review

	above their delegated authority.	that should have gone to executives or the Board.		system blocks approval above authority level.	annually
6	Finance could approve security spend without checking the security priority.	Budget may be allocated to lower-value activities while a serious risk remains open.	Finance, CISO, CEO	CISO sets risk priorities; Finance validates affordability; CEO/Executive Council resolves competing priorities.	Medium; quarterly budget review

5.4 Decision Recording and Assurance Note

Every material governance decision should have a short record. I would keep the record simple enough that managers will actually use it. At minimum it should show the date, issue, decision owner, decision, reason, evidence considered, actions, action owner, due date and review date.

The Risk or Governance team should maintain the decision log and check overdue actions before each Security Governance Committee meeting. For material decisions, the supporting evidence should be linked to the risk or incident record. Internal Audit or another independent assurance function can periodically sample the records to check that decisions were made by the right authority and that actions were actually completed.

A decision should not be marked closed just because a meeting agreed an action. Closure should require evidence that the action was completed, tested where appropriate, and accepted by the accountable owner.

Conclusion

The main governance problem at TechGlobal is not a lack of technical capability. It is that decision-making is concentrated in one area and there is no consistent way to challenge, escalate and record important security decisions. The proposed model spreads responsibility across the Board, CEO, CISO, Risk, Legal, Finance, HR, IT and Business Units.

The Executive Security Council gives senior management a place to make strategic decisions, while the Security Governance Committee handles regular cross-functional

governance. The Incident and Resilience Working Group keeps operational readiness active. The RACI matrix and escalation workflow then make it clearer who should act and who should make the final decision.

I would review the model after the first six months. The review should look at whether decisions are being made at the right level, whether risks are being escalated on time, whether exceptions are closing, and whether business units are actually using the governance process. If the committees are creating unnecessary delays, their scope should be adjusted rather than adding more bureaucracy.

References

1. National Institute of Standards and Technology (NIST). (2024). The NIST Cybersecurity Framework (CSF) 2.0, NIST CSWP 29.
2. National Institute of Standards and Technology (NIST). (2024). CSF 2.0 – Govern Function, including GV.RR Roles, Responsibilities and Authorities.
3. ICDFA. (2026). GRC102 Practical Laboratory – Week 3: Roles, Responsibilities and Accountability in Security Governance. TechGlobal Governance Transformation Simulation.

Framework note: The governance design above uses NIST CSF 2.0 as a supporting reference, especially its emphasis on governance, risk management, and clearly defined roles and authorities. The TechGlobal scenario and required evidence are taken from the ICDFA laboratory brief.